

Лекция 11. Угрозы безопасности информации на транспортном уровне модели OSI

Учебные вопросы:

1. Угрозы безопасности уровня 4 модели OSI.
2. TCP-атаки.
3. Land-атака.
4. UDP-атаки.
5. Атаки сканирования портов TCP и UDP.

1. Рассмотрим угрозы безопасности уровня 4 модели OSI.

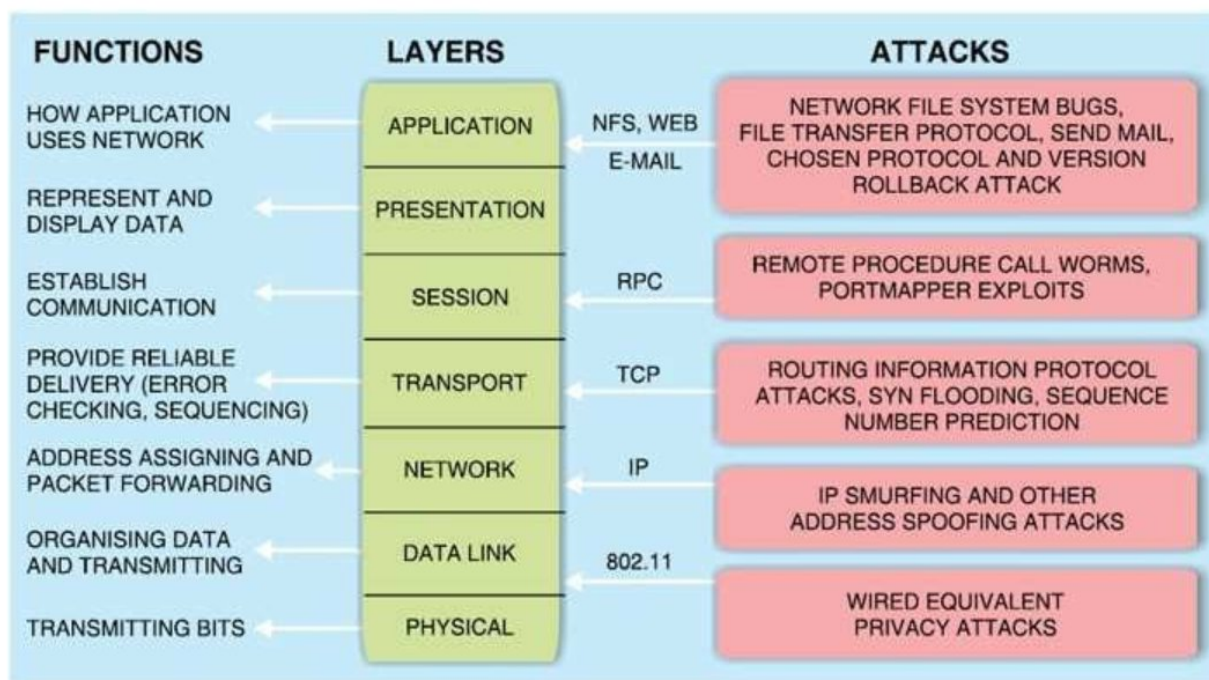


Рис. 1 Угрозы безопасности уровня 4 модели OSI



TCP и UDP — это транспортные протоколы уровня 4 модели OSI, отвечающие за транспортировку данных, скорость, надёжность. TCP более комплексный протокол, чем UDP, потому что это протокол, ориентированный на соединение, который имеет механизм

управления потоком (размером окна), в то время как UDP более простой и не требует установления соединения, а также не имеет механизмов управления потоком.

2. TCP-атаки

SYN-флуд

TCP-соединение устанавливается с помощью трёхэтапного рукопожатия. Злоумышленник может использовать это свойство протокола, отправляя очень большое количество пакетов SYN, не обращая внимания на SYN/ACK, которые отправляет атакуемый хост в запрашиваемую сторону.

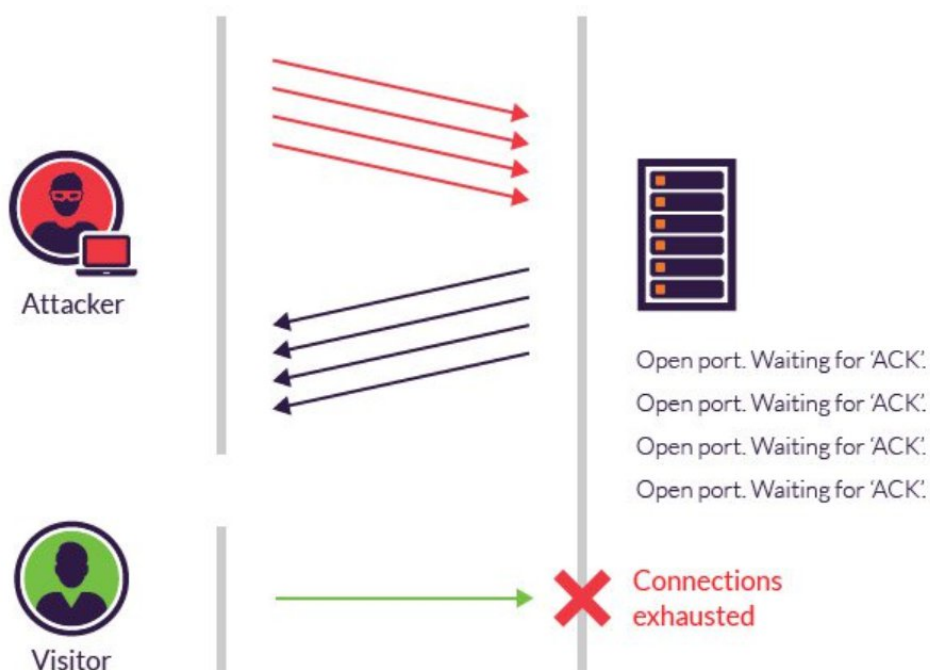


Рис. 2 SYN-флуд атака

Этот тип атаки называется атакой TCP SYN атакой или **SYN-флудом**.

SYN-флуд может быть успешным, поскольку атакуемый компьютер отслеживает частично открытые соединения в течение как минимум 75 секунд в «очереди прослушивания». Очередь ограничена в различных реализациях TCP, поэтому поток SYN может заполнить её, что приведет к перезагрузке или сбою машины.

В Linux очередь прослушивания TCP отличается от версии ядра. Для ядер 2.2 и старше очередь прослушивания по умолчанию равна 1024 для соединений TCP в состоянии SYN_RECV.

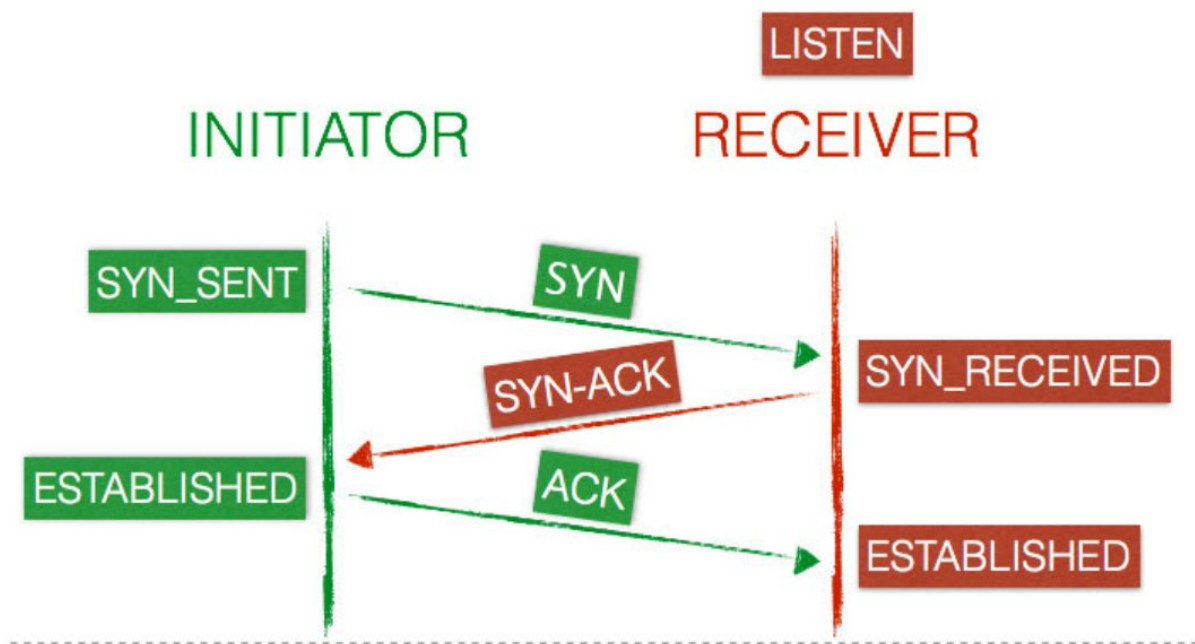


Рис. 2 Очередь прослушивания TCP

Очередь прослушивания можно просмотреть или изменить через параметр `sysctl tcp_max_syn_backlog`.

Получить значение:

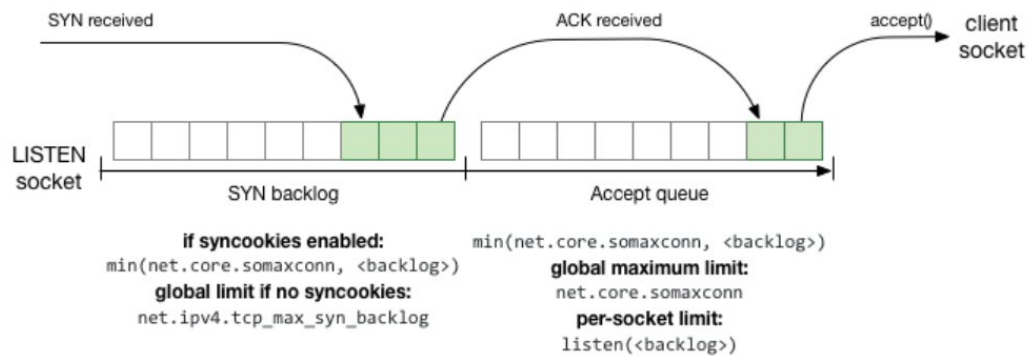
```
root@router:~# cat /proc/sys/net/ipv4/tcp_max_syn_backlog
```

Изменить значение (например, сделать равным 2048):

```
root@router:~# echo 2048 > /proc/sys/net/ipv4/tcp_max_syn_backlog
```

По умолчанию ядро Linux отбрасывает новые пакеты SYN, если очередь заполнена. Это поведение можно изменить с помощью параметра `sysctl tcp_syncookies`, который можно использовать только в том случае, если ядро Linux скомпилировано с поддержкой syncookies (`CONFIG_SYN_COOKIES="Y"`):

```
root@router:~# echo 1 > /proc/sys/net/ipv4/tcp_syncookies
```



Эта команда устанавливает для *tcp_syncookies* значение 1, и ядро Linux будет игнорировать размер *tcp_max_syn_backlog*.

Однако использование *tcp_syncookies* может иметь нежелательные побочные эффекты. Например, веб-сервер, который частично обрабатывает 1024 TCP-соединения, обычно отбрасывает новый пакет SYN при перегрузке. Это может привести новых клиентов к другому, менее загруженному веб-серверу, который может быстрее обработать их запрос. При включенных *syncookies* новые клиенты могут очень долго ждать ответа от перегруженного сервера.

Мы можем использовать *iptables* для защиты от SYN-флуда, ограничивая количество SYN-пакетов за определенный промежуток времени, как мы это делали для эхо-запросов ICMP:

```
root@router: ~# iptables -A INPUT -p tcp --syn -m limit --limit 10/s -j ACCEPT
```

```
root@router: ~# iptables -A INPUT -p tcp --syn -j DROP
```

3. Land-атака

Другой тип атаки, связанный с TCP - **Land-атака**. Она очень проста и в то же время очень разрушительна, так как от неё когда-то пострадало не только большое количество систем Unix и Windows, но и маршрутизаторы Cisco. Атака Land проводится с использованием небольшой программы, написанной на C (*land.c*), которая отправляет пакет SYN на хост через открытый TCP-порт с поддельным IP-адресом

источника равным IP-адресу назначения (например, 192.168.1.1, порт 139 -> 192.168.1.1, порт 139).

Другой популярной атакой, связанной с TCP, является атака типа «человек посередине», называемая перехватом TCP-соединения (**TCP Connection Hijacking**).

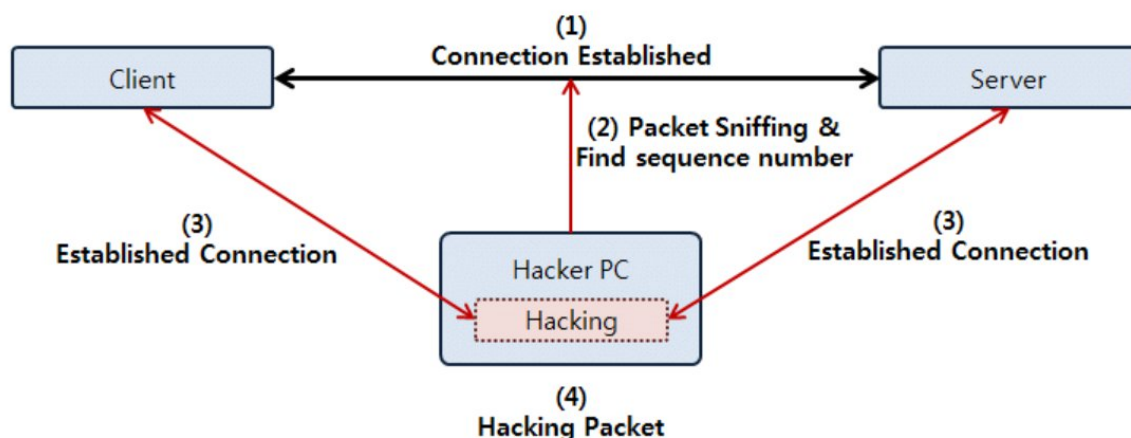


Рис. 4 Атака типа «человек посередине»

Злоумышленник, стоящий на пути двух компьютеров, обменивающихся данными по TCP, может захватить контроль над TCP-соединением во время трёхэтапного рукопожатия или после него, когда соединение уже установлено, путем создания десинхронизированного состояния, когда TCP-соединение установлено, данные не отправляются, а номер SEQ одного хоста не соответствует номеру ACK другого хоста и наоборот. В десинхронизированном состоянии узлы отбрасывают пакеты друг друга, но злоумышленник может создать последовательность правильных чисел, внедряя команды в соединение.

4. UDP-атаки

UDP-флуд

Поскольку UDP — это простой протокол без процедур установления соединения, единственный способ как-то повлиять на работу UDP - отправить большое количество пакетов UDP на

случайные порты атакуемой машины. Этот тип атаки называется **UDP-флудом**.

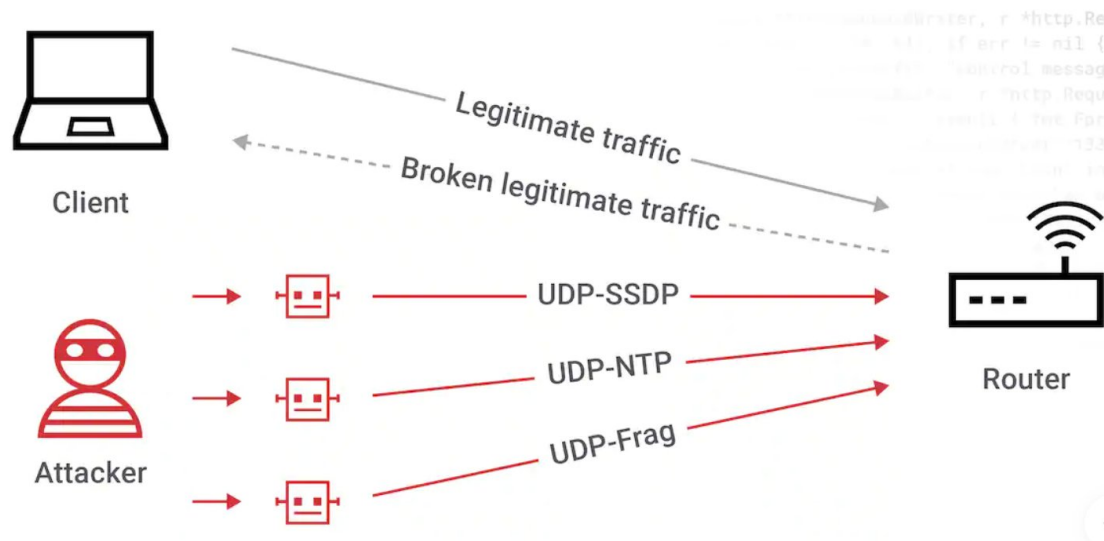


Рис. 5 UDP-флуд

Атакуемая машина попытается определить приложение, которому предназначен пакет. Если ни одно приложение не прослушивает этот порт UDP, пакет будет отброшен. Заливая жертву такими типами пакетов, компьютер жертвы может перегрузиться, что приведет к сбою системы.

5. Атаки сканирования портов TCP и UDP

Сканирование портов — это, вероятно, первое, что делает злоумышленник, пытающийся взломать жертву.

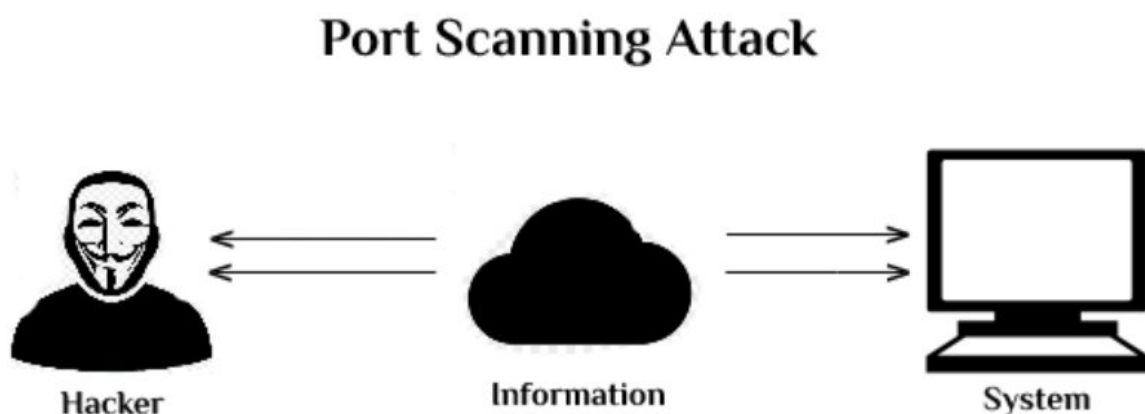


Рис. 6 Атака типа сканирование портов

Используя инструмент nmap, злоумышленник может узнать, какие порты TCP и UDP открыты на хосте, чтобы идентифицировать запущенные службы для дальнейшей эксплуатации уязвимостей.